

Script complet vidéo - Projet SOC externalisé Daylight

Équipe Cyber Trust : Kilyan FELIX, Yvan FOCSA, Youssef GUERNIOU, Mahamadou DIACOUMBA

Durée cible : 14 à 16 minutes. Ton attendu : présentation professionnelle, comme un prestataire externe face à un client.

0. Préparation avant enregistrement

- Ouvrir les schémas : Architecture globale, pfSense flux et règles, SOC Wazuh.
- Ouvrir pfSense : dashboard, interfaces, aliases, règles LAN, règles WAN, syslog, logs firewall.
- Ouvrir Wazuh : agents, événements pfSense, événements serveur, logs applicatifs Daylight, dashboards, RBAC.
- Ouvrir les documents d'exploitation : runbook de démarrage, playbooks, procédure de qualification et tableau SLA.
- Éviter de dire « on a bricolé » ou « on a simulé vite fait ». Dire plutôt « démonstrateur », « périmètre validé », « trajectoire d'industrialisation ».

1. Introduction projet - Kilyan FELIX - 1 min 30

À afficher : À afficher : page de garde du rapport groupe ou slide titre Cyber Trust / Daylight.

À dire : Bonjour, nous sommes l'équipe Cyber Trust. Dans le cadre de ce projet, nous avons travaillé pour le client fictif Daylight, un réseau de centres d'audioprothésistes répartis sur plusieurs sites en France.

À dire : La problématique de Daylight est simple : l'entreprise manipule des données sensibles, notamment des dossiers patients, mais ne dispose pas forcément d'une capacité interne suffisante pour superviser ses événements de sécurité. L'objectif demandé est donc de concevoir un SOC externalisé, démontrable, documenté et industrialisable.

À dire : Notre réponse repose sur trois axes : une architecture réseau segmentée, une plateforme SIEM open-source avec Wazuh, et une organisation SOC capable de qualifier les alertes, appliquer des procédures et produire un reporting lisible.

À dire : La répartition des rôles est la suivante : Yvan FOCSA porte l'architecture solution, la segmentation et pfSense ; Youssef GUERNIOU porte le périmètre SIEM Wazuh ; Kilyan FELIX porte la qualification des alertes, les dashboards et la priorisation ; Mahamadou DIACOUMBA porte l'exploitation, les procédures, les playbooks et le retour d'expérience.

Transition : « Nous allons commencer par l'architecture, car c'est le socle qui permet ensuite au SOC de superviser les bons événements. »

2. Architecture solution - Yvan FOCSA - 4 min

À afficher : À afficher : schéma Architecture globale.

À dire : Sur le périmètre architecture, l'objectif est de proposer une base réaliste pour Daylight, sans rester sur un réseau plat. L'architecture est organisée par zones : USERS pour les postes, SERVERS pour les services internes, DMZ pour l'application métier, MGMT pour l'administration, SOC pour la supervision Cyber Trust, et WAN pour l'exposition externe.

À dire : Cette segmentation répond directement au besoin client : limiter les mouvements latéraux, protéger les zones sensibles et rendre les flux observables. Les flux autorisés sont représentés en vert, les flux bloqués en rouge pointillé, et la journalisation vers le SOC en violet.

À dire : La logique de sécurité est de n'autoriser que les flux nécessaires. Les utilisateurs peuvent accéder à l'application Daylight en HTTPS, mais ne doivent pas accéder directement aux serveurs internes, à la zone d'administration ou à la zone SOC.

À afficher : À afficher : fichier Excel YVAN_Architecture_Zones_Flux_pfSense_Wazuh.xlsx, onglets zones et flux.

À dire : Pour rendre cette architecture maintenable, les zones, l'adressage, les flux, les interfaces, les ports Wazuh et les captures de preuve sont regroupés dans une matrice Excel. Ce fichier sert de base de reprise pour une équipe d'exploitation ou pour une extension multi-sites.

À afficher : À afficher : pfSense dashboard.

À dire : Dans le démonstrateur, pfSense est déployé en VM. Le dashboard montre que le firewall est opérationnel, avec une interface WAN en 192.168.5.128 et une interface LAN d'administration en 10.10.40.1. pfSense joue ici le rôle de point de contrôle réseau.

À afficher : À afficher : Interfaces Assignments.

À dire : Les interfaces sont bien séparées : WAN sur em0 et LAN sur em1. Cette séparation permet de distinguer la connectivité externe du lab et la zone d'administration utilisée pour les tests.

À afficher : À afficher : Aliases pfSense.

À dire : Les aliases pfSense permettent de rendre les règles lisibles. On retrouve par exemple ADMIN_SUBNET, SERVERS_SUBNET, SOC_SUBNET, DAYLIGHT_APP, SOC_WAZUH et DNS_ALLOWED. L'intérêt est de ne pas manipuler uniquement des IP brutes, mais des objets compréhensibles par une équipe technique.

À afficher : À afficher : Rules LAN.

À dire : Les règles LAN illustrent la politique de sécurité. Le DNS est autorisé vers les résolveurs connus, l'application Daylight est accessible en HTTPS, puis les accès vers les serveurs, la zone admin et le SOC sont bloqués. La navigation web reste autorisée sur 80 et 443.

À afficher : À afficher : règles WAN.

À dire : Côté WAN, aucune règle entrante permissive n'est ajoutée dans le lab. C'est volontaire : la posture par défaut est restrictive. Toute publication future, comme un VPN ou un portail exposé, devra être justifiée et validée.

À afficher : À afficher : Syslog Wazuh puis pfSense block.

À dire : pfSense envoie ensuite ses journaux vers Wazuh en syslog UDP 514, vers 10.10.50.10. Quand un flux est bloqué, l'événement apparaît d'abord dans les logs firewall pfSense.

À afficher : À afficher : Wazuh alertes pfSense 110010 / 110020.

À dire : La preuve finale est côté Wazuh : les événements pfSense remontent dans le SIEM avec les règles 110010 pour le trafic WAN bloqué et 110020 pour les tentatives de mouvement latéral vers MGMT. Cela montre que l'architecture réseau alimente réellement la supervision SOC.

Transition : Transition : « Une fois cette base réseau posée, le rôle du SIEM est de collecter, corrélérer et restituer ces événements. »

3. SIEM Wazuh - Youssef GUERNIOU - 4 min

À afficher : À afficher : dashboard Wazuh ou vue des composants Wazuh.

À dire : La partie SIEM repose sur Wazuh, déployé en environnement reproductible. La plateforme est organisée autour du Wazuh Manager, de l'Indexer et du Dashboard. Le Manager analyse les événements, l'Indexer stocke et permet la recherche, et le Dashboard fournit l'interface web pour les analystes.

À dire : Le choix de Wazuh répond au cahier des charges : solution open-source, centralisation des événements, règles personnalisables, interface web, dashboards et capacité d'intégration avec plusieurs sources de logs.

À afficher : À afficher : Explore agent avec serveur-01 et/ou poste-01.

À dire : La collecte est multi-source. Le projet démontre au minimum trois familles de sources : un endpoint Windows, un serveur Linux et des logs applicatifs Daylight. Cette diversité est importante, car un SOC ne doit pas se limiter à une seule source technique.

À afficher : À afficher : événements endpoint poste-01 / SCA Windows si disponible.

À dire : Pour le poste Windows, l'agent Wazuh permet de remonter des événements endpoint et des contrôles de conformité. Cela répond au besoin de supervision des postes utilisés par les audioprothésistes : authentifications locales, exécutions suspectes, conformité et usage potentiel de périphériques.

À afficher : À afficher : serveur-01 brute force SSH / rule 5710, 5712 ou équivalent.

À dire : Pour le serveur Linux, un agent Wazuh est installé sur serveur-01. Une attaque SSH par force brute a été simulée afin de prouver que les événements d'authentification remontent et déclenchent des alertes. Cette démonstration couvre le besoin de surveillance des serveurs internes.

À afficher : À afficher : logs applicatifs Daylight / règles métier.

À dire : La troisième source correspond aux logs applicatifs Daylight : CRM, rendez-vous et dossiers patients. Des règles métier permettent de détecter des comportements anormaux, par exemple un accès suspect à des dossiers patients ou une activité applicative inhabituelle.

À afficher : À afficher : dashboards technique et exécutif.

À dire : Deux niveaux de restitution sont prévus : un dashboard technique pour les analystes, avec les règles, sources et sévérités ; et un dashboard exécutif plus lisible pour le pilotage, avec les alertes critiques, les volumes et la répartition par site ou famille d'événements.

À afficher : À afficher : RBAC analyste/supervision/admin.

À dire : Enfin, l'accès à l'interface est segmenté par rôles. Les profils analyste et supervision ont des accès en lecture adaptés, tandis que l'administrateur conserve les droits de configuration. Cette segmentation répond à l'exigence du cahier des charges sur les vues supervision, analyste et admin.

Transition : Transition : « Les événements sont maintenant collectés ; il faut ensuite les prioriser et les qualifier pour qu'ils deviennent actionnables. »

4. Détection, qualification et pilotage SOC - Kilyan FELIX - 3 min

À afficher : À afficher : dashboard exécutif ou tableau de qualification.

À dire : Sur la partie détection et pilotage, l'objectif est de transformer les alertes techniques en informations exploitables par le SOC et compréhensibles par le client. Une alerte brute n'a de valeur que si elle est priorisée, qualifiée et rattachée à une procédure de réponse.

À dire : La qualification repose sur plusieurs critères : la sévérité Wazuh, la source concernée, la zone réseau, le type d'actif, l'impact potentiel et la répétition de l'événement. Par exemple, une tentative vers la zone MGMT ou un accès anormal à un dossier patient est prioritaire, car elle touche une zone sensible ou une donnée métier critique.

À afficher : À afficher : exemples d'alertes critiques dans Wazuh.

À dire : Les alertes sont classées par priorité. Les événements critiques doivent être traités rapidement, tandis que les alertes faibles peuvent alimenter le reporting ou l'analyse de tendance. Cette priorisation évite que l'équipe SOC perde du temps sur des événements peu importants.

À afficher : À afficher : dashboard technique puis dashboard exécutif.

À dire : Les dashboards ont deux usages. Le dashboard technique sert aux analystes pour enquêter : source, règle, sévérité, horodatage et détail de l'événement. Le dashboard exécutif sert à donner une vision synthétique au client : nombre d'alertes, criticité, tendances et périmètre impacté.

À dire : Cette approche permet de répondre à la fois aux besoins opérationnels du SOC et aux besoins de pilotage de Daylight. Le client ne reçoit pas uniquement des logs ; il reçoit une lecture claire du niveau de risque et des actions à engager.

Transition : Transition : « Une fois l'alerte qualifiée, il faut pouvoir appliquer une procédure claire et reproductible. »

5. Exploitation, runbooks et playbooks - Mahamadou DIACOUMBA - 2 min 30

À afficher : À afficher : runbook de démarrage ou procédure lab.

À dire : La partie exploitation garantit que le démonstrateur peut être relancé, maintenu et utilisé par l'équipe. Le projet documente les commandes de démarrage, les prérequis, les vérifications et les actions à effectuer après extinction du PC ou redémarrage des conteneurs.

À dire : L'objectif est de rendre l'environnement reproductible. Un SOC externalisé ne peut pas dépendre uniquement de la personne qui a installé le lab ; il faut des procédures suffisamment claires pour qu'un autre membre de l'équipe puisse reprendre l'exploitation.

À afficher : À afficher : playbook incident brute force / mouvement latéral / accès dossier patient.

À dire : Des playbooks sont associés aux scénarios principaux : brute force SSH, accès anormal à un dossier patient, tentative de mouvement latéral vers l'administration, ou événement firewall critique. Chaque playbook décrit le contexte, les critères de qualification, les premières vérifications et les actions de réponse attendues.

À afficher : À afficher : document REX ou procédure de clôture incident.

À dire : Enfin, le retour d'expérience permet d'améliorer les règles et les procédures après un incident. Si une alerte est trop bruyante, elle doit être ajustée. Si une procédure manque d'informations, elle doit être enrichie. C'est cette boucle d'amélioration qui rend la solution industrialisable.

Transition : Transition : « Nous pouvons maintenant conclure sur la valeur globale de la solution proposée à Daylight. »

6. Conclusion générale - Kilyan ou toute l'équipe - 1 min

À afficher : À afficher : schéma architecture globale ou dashboard exécutif.

À dire : Pour conclure, le démonstrateur Cyber Trust répond au besoin de Daylight : centraliser les événements de sécurité, superviser plusieurs sources, détecter des comportements à risque, fournir des dashboards lisibles et proposer des procédures de réponse.

À dire : La solution est volontairement construite comme un MVP industrialisable. Elle ne prétend pas être une production complète haute disponibilité, mais elle démontre les briques essentielles : segmentation réseau, pfSense, Wazuh, collecte multi-source, règles de détection, RBAC, dashboards, qualification et playbooks.

À dire : Les perspectives d'évolution seraient d'ajouter la haute disponibilité pfSense/Wazuh, de sécuriser les flux syslog en production, d'étendre les règles métier, de connecter davantage de sites Daylight et d'automatiser une partie de la réponse SOC.

À dire : Ce projet montre donc comment Cyber Trust peut accompagner Daylight vers un SOC externalisé clair, exploitable et progressivement industrialisable.

7. Phrase de secours si la vidéo doit être raccourcie

À dire : Si la vidéo doit être plus courte, garder seulement : introduction client, schéma global, pfSense règles/syslog, Wazuh sources/dashboards/RBAC, qualification des alertes, playbooks, conclusion.